



Projeto open source · licença MIT

Portal de Provisionamento de Usuários Microsoft 365

Documentação completa: por que implantar, o que o portal faz, como ele protege a organização e como colocá-lo para funcionar no seu Microsoft 365 e na sua assinatura Azure.

Admissão

Aprovação

Acesso inicial seguro

Desligamento

Auditoria

LGPD

Sem senhas nem segredos

Sumário

PARTE I — VISÃO GERAL

1	Resumo executivo	3
2	O problema: entrada e saída de pessoas feitas à mão	3
3	A solução em uma página	4
4	Por que implantar: benefícios e riscos evitados	5
5	Quem usa o portal	6

PARTE II — FUNCIONALIDADES

6	Admissão de um novo colaborador	7
7	Aprovação e segregação de funções	10
8	Primeiro acesso do colaborador	11
9	Desligamento	12
10	Administração, painel e perfis	13
11	Auditoria e privacidade (LGPD)	16
12	Interface	17

PARTE III — TÉCNICA

13	Arquitetura	18
14	Segurança	19
15	Permissões no Microsoft 365	20
16	Implantação passo a passo	22
17	Publicação automática (GitHub Actions)	23
18	Operação e solução de problemas	23
19	Configurações	24

APÊNDICES

A	Glossário	25
B	Estrutura do repositório e licença	25

Visão geral

1 Resumo executivo

O Portal de Provisionamento transforma a entrada e a saída de colaboradores no Microsoft 365 em um processo único, aprovado e registrado: o RH pede, outra pessoa aprova e o portal executa cada etapa no momento certo — sem senhas trafegando e sem acessos esquecidos.

Em muitas empresas, criar a conta de quem está chegando e remover os acessos de quem está saindo depende de e-mails, planilhas e da memória de alguém da TI. Isso gera contas criadas antes da hora, senhas enviadas por mensagem, licenças pagas sem uso e ex-colaboradores com acesso depois do último dia. O portal resolve esses pontos com um fluxo padronizado:

- **Admissão:** a conta é criada *desativada* logo após a aprovação, recebe a licença só na véspera e é ativada no dia da admissão. O gestor gera um código de acesso de uso único, e o colaborador cadastra a própria senha e o MFA no primeiro acesso.
- **Desligamento:** no último dia, no horário definido, a conta é bloqueada, as sessões são encerradas e o colaborador sai dos grupos e das licenças. A conta nunca é excluída automaticamente.
- **Controle:** quem pede não aprova; cada ação fica na trilha de auditoria; os dados pessoais podem ser anonimizados depois de um prazo (LGPD).

0

senhas ou segredos guardados pelo portal

4

papéis com permissões separadas

1 h

intervalo máximo do agendador

R\$ 0

de infraestrutura no laboratório (plano gratuito)

O projeto é **open source (licença MIT)** e genérico: cada organização implanta no próprio Microsoft 365 e na própria assinatura Azure. Nenhum dado de cliente fica no repositório.

2 O problema: entrada e saída de pessoas feitas à mão

A conta no Microsoft 365 é a porta de entrada para e-mail, arquivos, Teams e, muitas vezes, para outros sistemas da empresa. Quando a criação e a remoção dessa conta são manuais, os mesmos problemas aparecem em quase toda organização:

Situação comum	Consequência
Conta criada e ativada dias antes da admissão	Uma conta válida, sem dono ativo, fica exposta a ataques; a licença já está sendo paga.
Senha inicial enviada por e-mail ou mensagem	Qualquer pessoa com acesso à mensagem entra na conta antes do colaborador; o MFA ainda não existe.

Situação comum	Consequência
Pedido feito por e-mail ou planilha	Sem aprovação formal, sem histórico, com erros de digitação no nome e no login.
Grupos e acessos escolhidos "de cabeça"	Cada novo colaborador recebe acessos diferentes para a mesma função; acessos a mais passam despercebidos.
Desligamento depende de lembrar	Ex-colaboradores continuam com e-mail no celular, Teams aberto e acesso a arquivos depois do último dia.
Nenhum registro de quem fez o quê	Em uma auditoria ou incidente não há como provar quem pediu, quem aprovou e quando a conta foi bloqueada.
Dados pessoais guardados para sempre	Planilhas e e-mails com nome, matrícula e cargo ficam indefinidamente, contrariando a LGPD.

Por que isso importa

Contas órfãs e acessos que não foram removidos estão entre as causas mais frequentes de incidentes de segurança. O desligamento é o momento mais sensível: a pessoa ainda conhece os sistemas e, sem um processo, pode continuar entrando.

3 A solução em uma página

O portal é um site interno, com login pela conta corporativa do Microsoft 365. Ele centraliza os pedidos do RH, a aprovação e a execução, que é feita automaticamente pelo próprio portal no Microsoft 365.

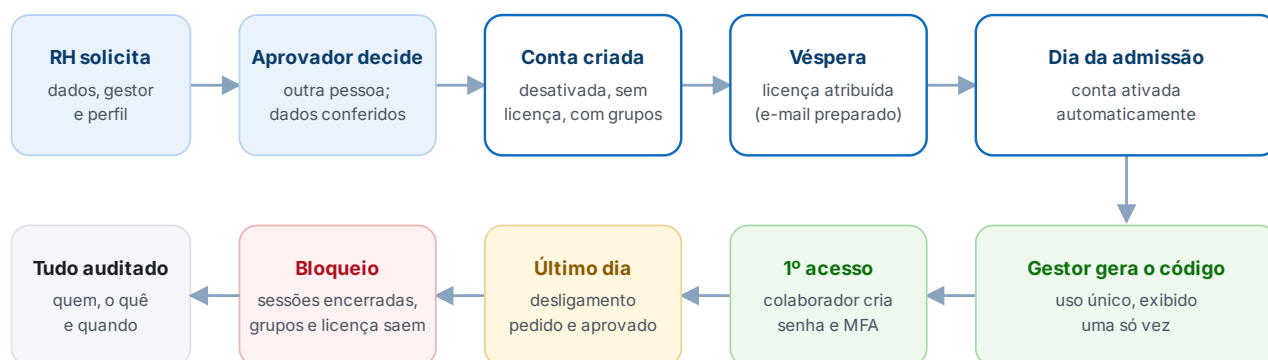
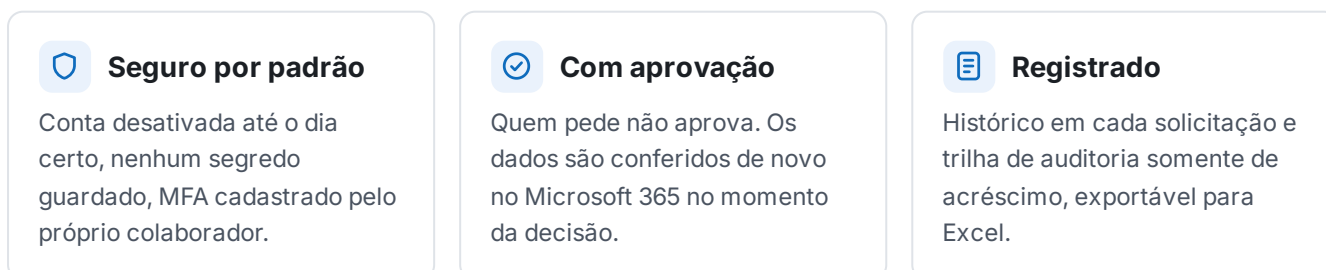


Figura 1. Jornada completa de um colaborador no portal, da solicitação do RH ao bloqueio no último dia.



4 Por que implantar: benefícios e riscos evitados

O portal não é só uma forma mais rápida de criar contas. Ele muda *quando* e *como* cada acesso existe, o que reduz riscos reais de segurança, de custo e de conformidade.

Tema	Sem o portal	Com o portal
Conta antes da admissão	Ativa dias antes, com senha conhecida por terceiros	Existe, mas desativada; só é ativada no dia da admissão
Senha inicial	Definida pela TI e enviada por mensagem	Não existe: o gestor entrega um código de uso único e o colaborador cria a própria senha
MFA	Configurado "depois", quando alguém lembra	Cadastrado no primeiro acesso, com o código temporário
Licenças	Pagas desde a criação da conta	Atribuídas só na véspera da admissão e removidas no desligamento
Acessos por função	Escolhidos a cada pedido	Perfis de onboarding padronizados, validados pelo administrador
Desligamento	Depende de alguém lembrar; horário incerto	Agendado para o último dia, no horário definido, com sessões encerradas
Aprovação	Informal ou inexistente	Obrigatória, por outra pessoa, com comentário e histórico
Rastreabilidade	E-mails espalhados	Trilha de auditoria com quem, o quê e quando
LGPD	Dados pessoais guardados sem prazo	Retenção configurável, anonimização automática e aviso de privacidade

Benefícios por área

RH

Pede admissões e desligamentos sozinho, em um formulário que valida os dados e mostra o login que será criado. Acompanha o andamento sem precisar cobrar a TI.

TI e Segurança

Deixa de digitar contas e de lembrar desligamentos. Aprova com um clique, com os dados conferidos no Microsoft 365. Sabe exatamente quais acessos cada perfil concede.

Gestores

Recebem o novo colaborador no primeiro dia com um código de acesso gerado por eles mesmos, na hora certa, sem depender da TI.

Diretoria, auditoria e DPO

Têm evidência de cada decisão (quem pediu, quem aprovou, quando foi executado), segregação de funções e política de retenção de dados pessoais.

Custo

O portal roda em serviços simples do Azure. Em laboratório, o plano gratuito do App Service é suficiente e os demais recursos custam centavos por mês. Em produção, recomenda-se um plano pago básico (B1 ou superior) para ficar sempre disponível. Não há licença do portal: o código é livre. A economia com licenças do Microsoft 365, atribuídas só na véspera e removidas no desligamento, tende a superar o custo da infraestrutura.

5 Quem usa o portal

O acesso é controlado por **papéis** do Microsoft Entra ID, atribuídos a grupos. Para dar ou tirar acesso, basta incluir ou remover a pessoa do grupo correspondente — nada é configurado no portal.

Papel	Quem normalmente é	O que pode fazer
Solicitante	RH	Pedir admissões e desligamentos; acompanhar e cancelar os próprios pedidos.
Aprovador	TI / Segurança	Aprovar ou rejeitar pedidos feitos por outras pessoas (com comentário obrigatório na rejeição).
Administrador	Responsável pelo portal	Painel, todas as solicitações, perfis de onboarding, recursos do Microsoft 365, auditoria e privacidade; reprocessar etapas.
Gestor	Qualquer gestor da empresa	Não é um papel: todo gestor registrado em uma admissão vê a sua equipe em <i>Minha equipe</i> e gera o código de acesso inicial.
Agendador	O próprio sistema	Papel exclusivo da identidade do agendador (não de pessoas); executa licenças, ativações e desligamentos de hora em hora.

Segregação de funções

Mesmo quem tem os papéis de Solicitante e Aprovador não consegue aprovar o próprio pedido. Ninguém pede, aprova ou cancela o próprio desligamento, e o colaborador em desligamento nem enxerga o pedido.

Funcionalidades

6 Admissão de um novo colaborador

A página inicial mostra os papéis da pessoa, os atalhos para *Novo colaborador* e *Desligamento* e avisos do que precisa de atenção, como aprovações pendentes e colaboradores que começam hoje.

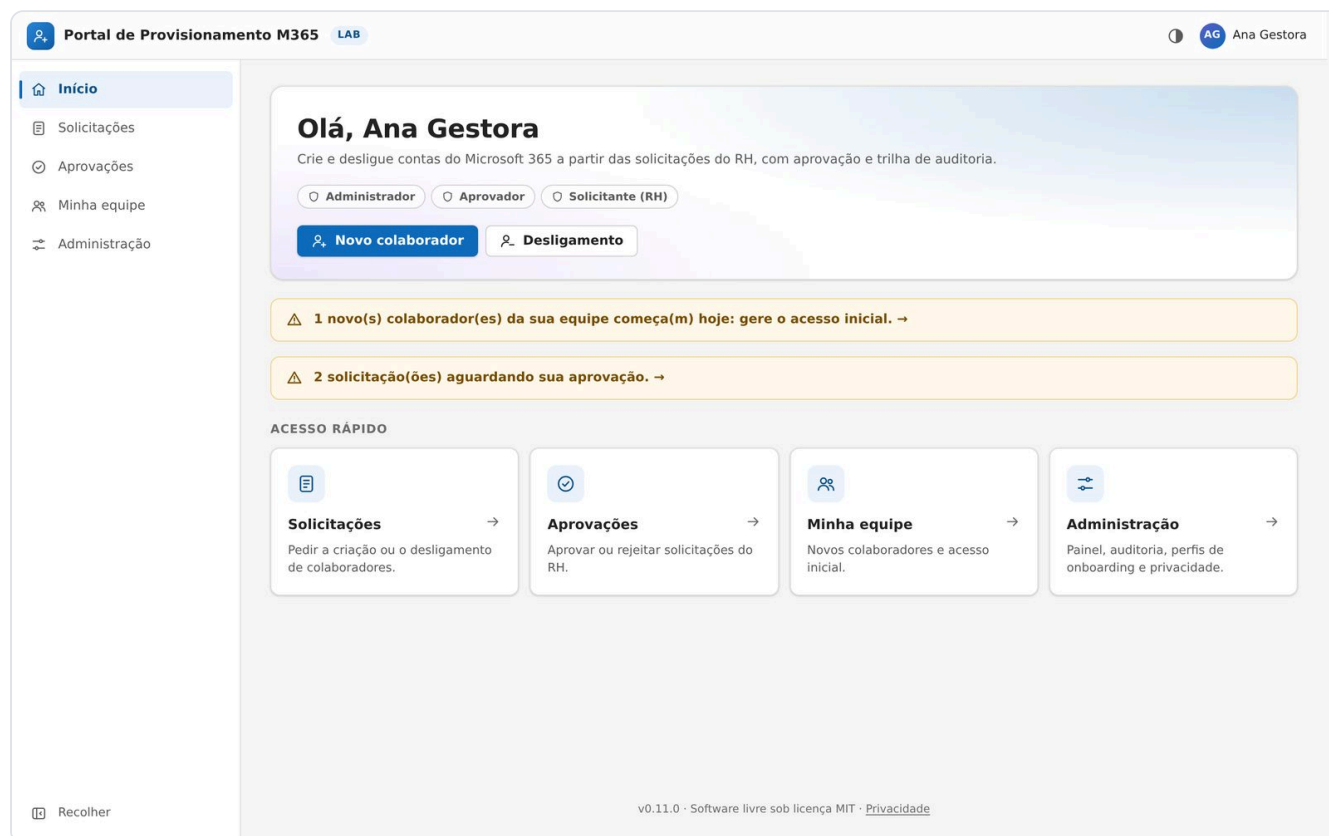


Figura 2. Página inicial com atalhos, avisos e acesso rápido às áreas do portal.

6.1 Formulário

O RH informa nome, sobrenome, matrícula, tipo de colaborador, cargo, departamento, local, data de admissão, perfil de onboarding e gestor. O gestor é escolhido por uma busca no diretório da empresa — não é digitado —, o que evita erros.

The screenshot shows a web application titled 'Portal de Provisionamento M365' with a user 'Ana Gestora'. The main form is 'Novo colaborador' and is divided into several sections:

- Identificação:** Fields for 'Nome' (Juliana), 'Sobrenome' (Carvalho), and 'Nome de exibição' (optional, default: nome + sobrenome).
- Matrícula:** Field with value '3010'.
- Tipo de colaborador:** Dropdown menu set to 'Funcionário'.
- Cargo e organização:** Fields for 'Cargo' (Analista de Marketing), 'Departamento' (Financeiro), 'Empresa', and 'Unidade'.
- Cidade, Estado, País:** Fields for 'Cidade' (São Paulo), 'Estado' (SP), and 'País' (Brasil).
- Admissão:** Fields for 'Data de admissão' (10/08/2026) and 'Perfil de onboarding' (Financeiro — Funcionário).
- Gestor:** A dropdown menu showing 'Ana Gestora — Gerente Financeira'.

At the bottom of the form are buttons for 'Revisar' and 'Cancelar'. The footer of the page includes 'v0.11.0 - Software livre sob licença MIT - Privacidade'.

Figura 3. Formulário de novo colaborador. Os campos respeitam os limites do Microsoft 365 e a data de admissão tem janela permitida.

6.2 Revisão antes de enviar

Antes de enviar, o portal mostra exatamente o que será criado: nome de exibição, login, e-mail, grupos, licença e a linha do tempo. Nesse momento ele já:

- **gera o login** seguindo o padrão da empresa (por exemplo, `nome.sobrenome`), remove acentos e trata partículas como "da" e "dos";
- **resolve colisões:** se `joao.silva` já existe em um usuário, grupo, e-mail ou apelido, sugere `joao.silva2`;
- **confere a matrícula** contra o Microsoft 365 e contra outras solicitações em andamento;
- **valida o perfil e o gestor** (o gestor precisa estar ativo).

Portal de Provisionamento M365 LA8 Ana Gestora

Revisar criação do usuário

Conta

Nome completo: Juliana Carvalho
 Nome de exibição: Juliana Carvalho
 Login: juliana.carvalho@contoso.com
 E-mail: juliana.carvalho@contoso.com
 Apelido de e-mail: juliana.carvalho
 Matrícula: 3010
 Tipo: Funcionário

Organização

Cargo: Analista de Marketing
 Departamento: Financeiro
 Local: São Paulo - SP - Brasil
 Gestor: Ana Gestora (ana.gestora@contoso.com)

Acessos e licença

Perfil: Financeiro — Funcionário
 Grupos: Financeiro, VPN - Usuários
 Licença: Licença - Microsoft 365 E3

Linha do tempo

- 1 **Após a aprovação:** conta criada desativada, sem licença, com gestor e grupos.
- 2 **07/10/2026:** licença atribuída (caixa de correio preparada).
- 3 **08/10/2026 (admissão):** conta ativada; o gestor gera o código de acesso inicial no portal.

[Enviar solicitação](#) [Voltar e editar](#)

Recolher v0.11.0 - Software livre sob licença MIT - [Privacidade](#)

Figura 4. Tela de revisão: o RH confere login, e-mail, acessos e datas antes de enviar.

6.3 Linha do tempo da conta

Quando	O que acontece	Situação
Envio	A solicitação recebe um número (REQ- AAAAMDD -NNNN) e aguarda aprovação.	Aguardando aprovação
Aprovação	Conta criada desativada , sem licença, com gestor, matrícula, data de admissão e grupos de acesso do perfil. A senha gerada é aleatória e descartada: ninguém a conhece.	Conta criada
Véspera da admissão	A conta entra no grupo de licença (ou recebe a licença direta). A caixa de e-mail é preparada.	Licenciada
Dia da admissão	A conta é ativada . O gestor já pode gerar o código de acesso inicial.	Ativa

O agendador roda de hora em hora e é **idempotente**: rodar de novo não duplica nada. Se uma etapa falhar (por exemplo, falta de licenças), a solicitação fica em **Falha parcial**, o que já foi feito é mantido e a etapa é tentada de novo na próxima hora.

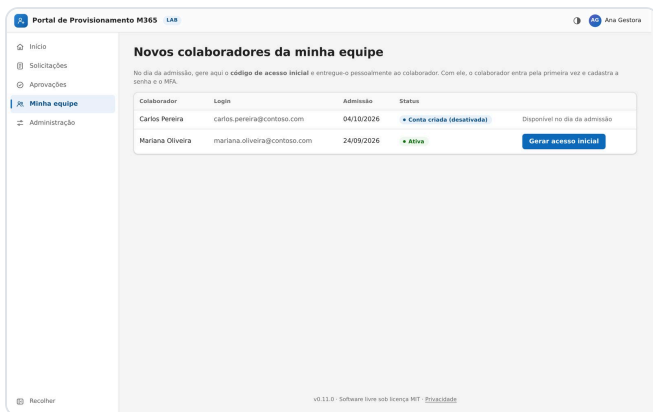


Figura 7. Minha equipe: novos colaboradores do gestor e o botão para gerar o acesso.

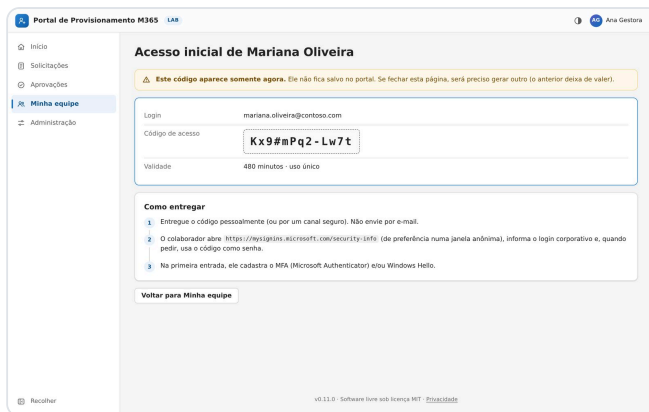


Figura 8. Código de acesso exibido uma só vez, com as instruções de entrega (código fictício).

O colaborador acessa `mysignins.microsoft.com/security-info`, informa o login corporativo, usa o código quando o sistema pedir a senha e, nessa primeira entrada, cadastra o MFA (Microsoft Authenticator) e/ou o Windows Hello. A partir daí, ninguém além dele conhece suas credenciais.

9 Desligamento

O RH escolhe o colaborador na busca do diretório (inclusive contas já desativadas), informa o último dia de trabalho e, se necessário, marca *bloquear imediatamente*. A revisão mostra os acessos atuais que serão removidos e as ações que precisarão ser feitas à mão.

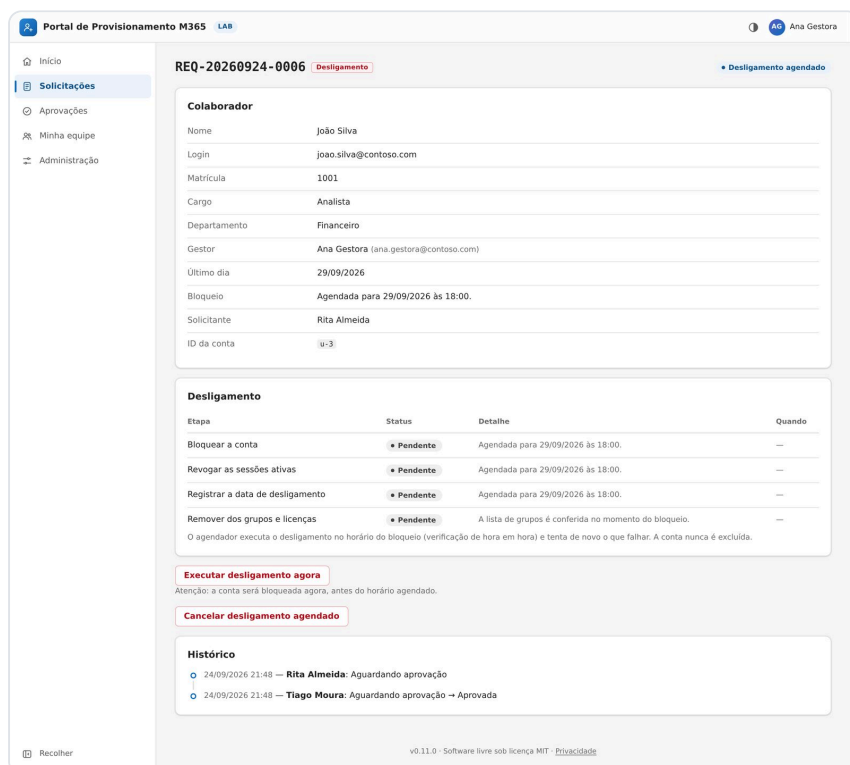


Figura 9. Desligamento aprovado e agendado para o último dia, com as etapas que serão executadas.

Etapas executadas no horário do bloqueio (padrão: 18h do último dia)

- 1 **Bloquear a conta** — sempre a primeira etapa.

- 2 **Encerrar as sessões ativas** — Outlook, Teams e navegadores deixam de funcionar em poucos minutos.
- 3 **Registrar a data de desligamento** no Microsoft 365.
- 4 **Remover dos grupos**, inclusive o de licença (a licença sai junto). A lista é conferida no momento do bloqueio, não no pedido.
- 5 **Remover licenças diretas**, quando o portal está configurado para atribuí-las assim.

O que fica como ação manual

Algumas situações não podem ou não devem ser feitas automaticamente. O portal as registra na solicitação como **Ação manual** :

Situação	Por quê
Grupos dinâmicos	A participação vem de uma regra; ajuste a regra ou os dados do usuário.
Listas de distribuição	São gerenciadas pelo Exchange.
Grupos ou funções administrativas	Exigem privilégio de administrador, que o portal propositalmente não recebe.
Subordinados diretos	O portal não altera o gestor de outras pessoas; o RH define o novo gestor.

A conta nunca é excluída

Ela fica bloqueada, preservando e-mails, arquivos e evidências para retenção, auditoria e LGPD. Se a pessoa não comparecer no primeiro dia, aprovar o desligamento encerra a admissão, e a conta nunca é ativada.

10 Administração, painel e perfis

Painel

Reúne o que o administrador precisa ver todos os dias: pedidos aguardando aprovação, em andamento e com falha, admissões e desligamentos dos próximos 7 dias, a última execução do agendador, as licenças disponíveis (com alerta quando estão acabando) e a atividade recente.

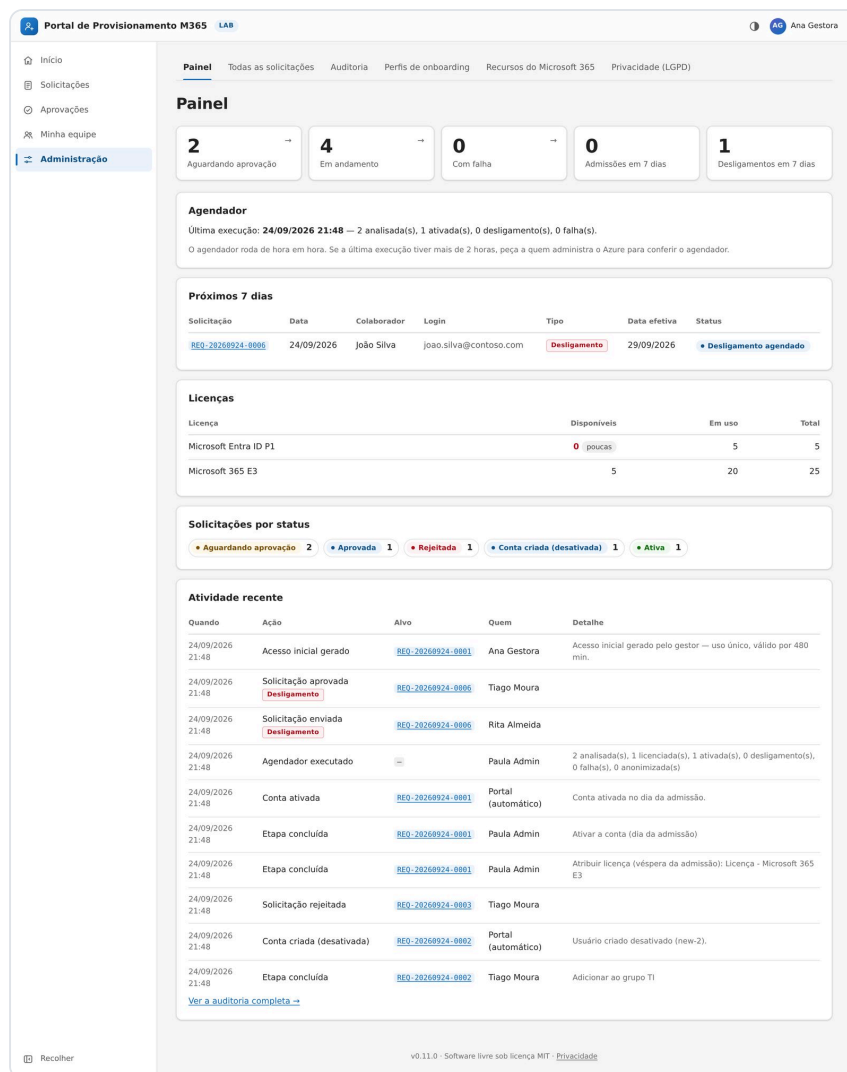


Figura 10. Painel do administrador.

Todas as solicitações

Lista completa com filtros por situação, o botão *Executar ciclo de vida agora* (que faz na hora o que o agendador faria na próxima execução) e, em cada solicitação com falha, o botão *Reprocessar etapas pendentes*.

Portal de Provisionamento M365

LAB

AG

Ana Gestora

Início

Solicitações

Aprovações

Minha equipe

Administração

Painel

Todas as solicitações

Auditoria

Perfis de onboarding

Recursos do Microsoft 365

Privacidade (LGPD)

Todas as solicitações

Executar ciclo de vida agora

O ciclo de vida (licença na véspera da admissão, ativação no dia da admissão e desligamentos agendados) roda automaticamente de hora em hora.

Solicitação	Data	Colaborador	Login	Tipo	Data efetiva	Solicitante	Status
REQ-20260924-0006	24/09/2026	João Silva	joao.silva@contoso.com	Desligamento	29/09/2026	Rita Almeida	Desligamento agendado
REQ-20260924-0005	24/09/2026	Lucas Fernandes	lucas.fernandes@contoso.com	Admissão	14/10/2026	Rita Almeida	Aguardando aprovação
REQ-20260924-0004	24/09/2026	Rafael Lima	rafael.lima@contoso.com	Admissão	09/10/2026	Rita Almeida	Aguardando aprovação
REQ-20260924-0003	24/09/2026	Beatriz Souza	beatriz.souza@contoso.com	Admissão	06/10/2026	Rita Almeida	Rejeitada
REQ-20260924-0002	24/09/2026	Carlos Pereira	carlos.pereira@contoso.com	Admissão	04/10/2026	Rita Almeida	Conta criada (desativada)
REQ-20260924-0001	24/09/2026	Mariana Oliveira	mariana.oliveira@contoso.com	Admissão	24/09/2026	Rita Almeida	Ativa

Recolher

v0.11.0 · Software livre sob licença MIT · [Privacidade](#)

Figura 11. Todas as solicitações, com tipo, data efetiva e situação.

Perfis de onboarding

Cada perfil define os **grupos de acesso** e a **licença** de uma função (por exemplo, "Financeiro — Funcionário"). O RH só escolhe o perfil; nunca escolhe grupos. Ao salvar um perfil, o portal confere no Microsoft 365 que cada grupo existe, é de segurança, não é dinâmico, não concede funções administrativas e não é um grupo de papel do próprio portal.

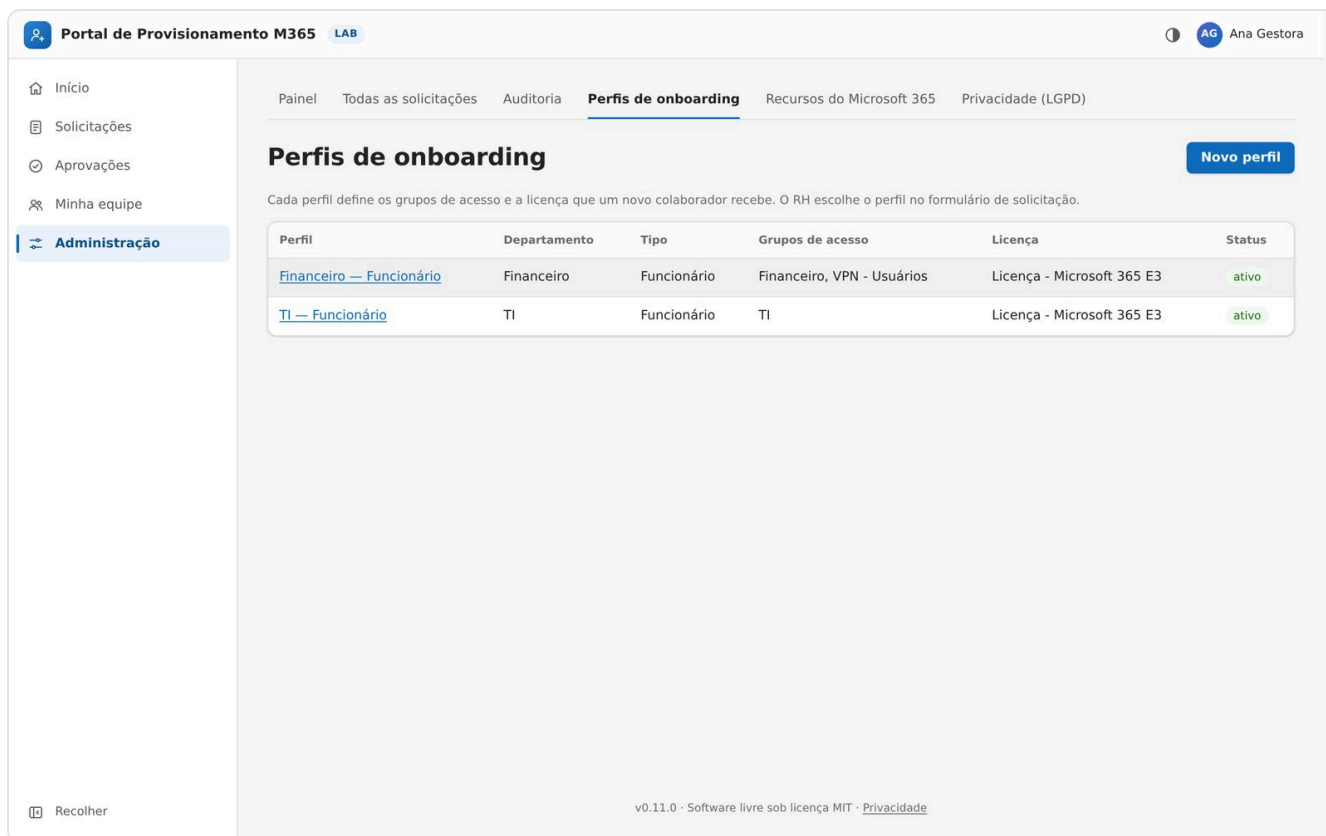


Figura 12. Perfis de onboarding: grupos de acesso e licença de cada função.

Recursos do Microsoft 365

Mostra o que a organização tem disponível e como o portal está configurado: domínios verificados, recursos (Entra ID P1/P2, Governance, Exchange Online, código de acesso temporário), licenças com unidades livres e quais grupos podem ser usados em perfis. Bloqueios e avisos de configuração aparecem em destaque.

11 Auditoria e privacidade (LGPD)

Trilha de auditoria

Toda mudança em solicitações e perfis gera eventos automaticamente: envio, aprovação, rejeição, cancelamento, criação, licença, ativação, desligamento, cada etapa, geração do código de acesso (sem o código), alterações de perfis, execuções do agendador, anonimizações e exportações.

- **Somente acréscimo:** o portal não altera nem apaga eventos.
- **Minimização:** o evento identifica a solicitação pelo número; nome, login e e-mail do colaborador não entram na auditoria. Quem executou cada ação é mantido para responsabilização.
- **Exportação para Excel** (CSV com separador ";"), protegida contra injeção de fórmulas.

Portal de Provisionamento M365

LAB

AG

Ana Gestora

Início

Solicitações

Aprovações

Minha equipe

Administração

Painel

Todas as solicitações

Auditoria

Perfis de onboarding

Recursos do Microsoft 365

Privacidade (LGPD)

Ação

Solicitação / alvo

Quem

Todas

REQ-AAAAMDD-NNNN

De

Até

mm/dd/yyyy

mm/dd/yyyy

Filtrar

Limpar

Exportar CSV

Registro somente de acréscimo: quem fez o quê e quando. Não contém senhas, códigos de acesso nem dados pessoais do colaborador (o alvo é o número da solicitação).

Quando	Ação	Alvo	Quem	Detalhe
24/09/2026 21:48	Acesso inicial gerado	REQ-20260924-0001	Ana Gestora	Acesso inicial gerado pelo gestor — uso único, válido por 480 min.
24/09/2026 21:48	Solicitação aprovada Desligamento	REQ-20260924-0006	Tiago Moura	
24/09/2026 21:48	Solicitação enviada Desligamento	REQ-20260924-0006	Rita Almeida	
24/09/2026 21:48	Agendador executado	-	Paula Admin	2 analisada(s), 1 licenciada(s), 1 ativada(s), 0 desligamento(s), 0 falha(s), 0 anonimizada(s)
24/09/2026 21:48	Conta ativada	REQ-20260924-0001	Portal (automático)	Conta ativada no dia da admissão.
24/09/2026 21:48	Etapla concluída	REQ-20260924-0001	Paula Admin	Ativar a conta (dia da admissão)
24/09/2026 21:48	Etapla concluída	REQ-20260924-0001	Paula Admin	Atribuir licença (véspera da admissão): Licença - Microsoft 365 E3

Recolher

Figura 13. Auditoria com filtros por ação, solicitação, pessoa e período.

Privacidade

- **Retenção configurável:** depois do prazo (sugestão: 2 anos após a conclusão), o agendador anonimiza a solicitação — remove nome, login, e-mail, matrícula, cargo, gestor, comentários e detalhes das etapas. A conta no Microsoft 365 não é alterada.
- **Aviso de privacidade** para todos os usuários, com finalidade, dados tratados, base legal, retenção e contato do encarregado (DPO).
- **O motivo do desligamento não é pedido**, e o formulário orienta a não informá-lo.
- Os logs técnicos não recebem dados pessoais nem endereços do Microsoft 365.

Responsabilidade da organização

O portal ajuda a cumprir a LGPD, mas a política de retenção, a base legal e o registro das operações de tratamento são decisões da organização — valide com o seu encarregado de dados.

12 Interface

A interface segue o visual do Microsoft 365, com menu lateral, tema claro e escuro (automático, conforme o sistema operacional, ou escolhido pelo usuário) e adaptação para celular. O texto é em português simples, sem termos técnicos; informações para quem administra o Azure ficam recolhidas. As cores atendem ao contraste mínimo de acessibilidade (WCAG AA), é possível navegar pelo teclado e há atalho para pular direto ao conteúdo.

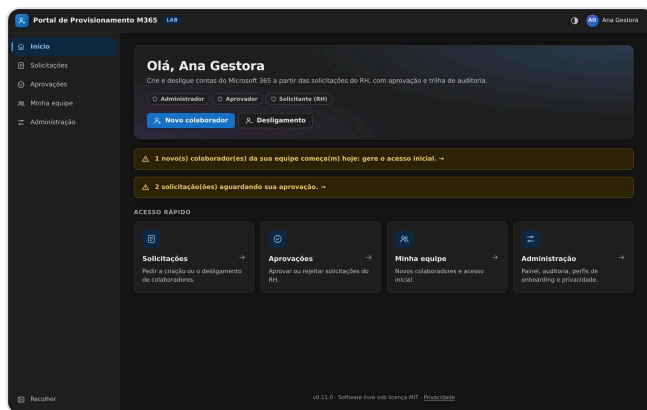


Figura 14. Tema escuro.

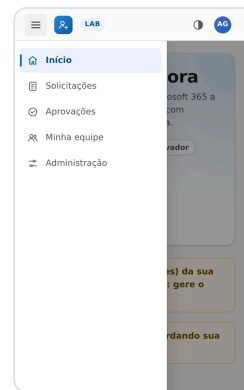


Figura 15. Celular, com o menu aberto.

PARTE III

Técnica

13 Arquitetura

O portal é uma aplicação web em Python (FastAPI) hospedada no Azure App Service. Todas as chamadas ao Microsoft 365 passam pelo Microsoft Graph usando uma **Managed Identity**, uma identidade do Azure que não tem senha nem segredo.

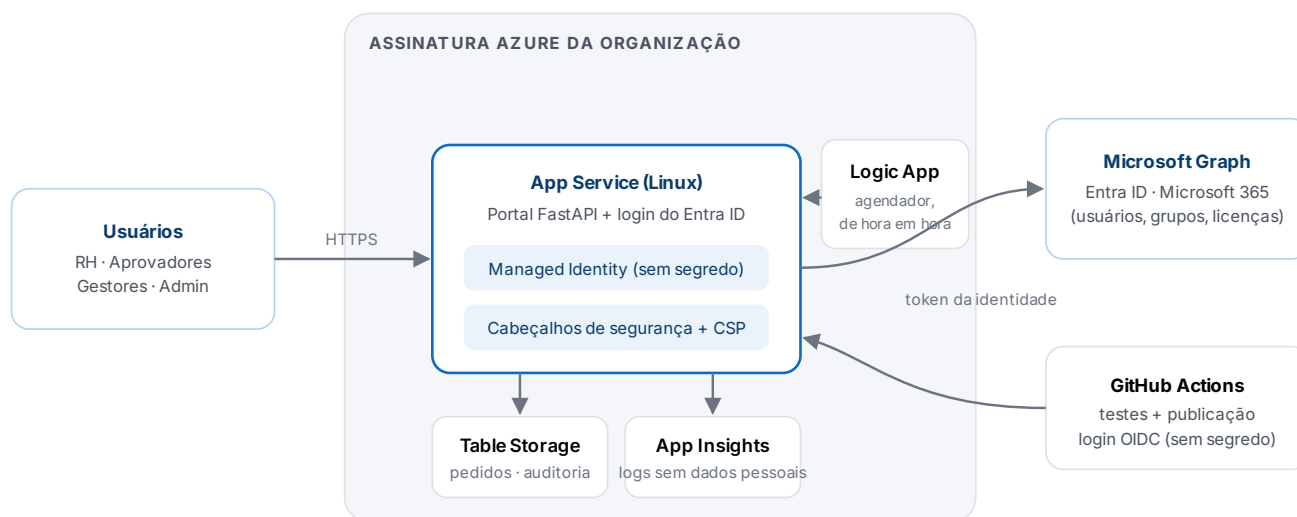


Figura 16. Componentes e conexões. Tudo fica na assinatura Azure e no Microsoft 365 da própria organização.

Situações de uma solicitação

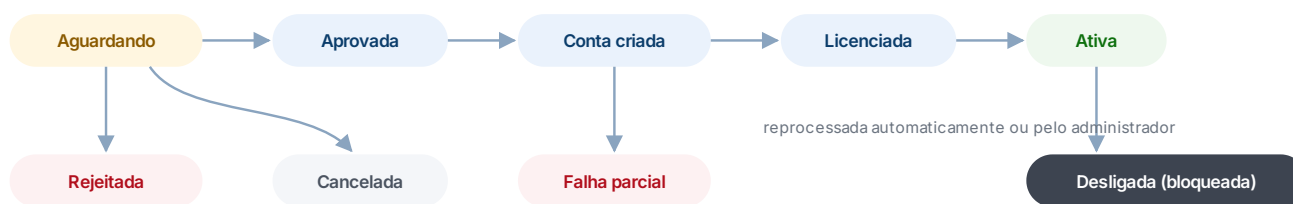


Figura 17. Principais situações de uma admissão. O desligamento segue Aguardando → Aprovada (agendado) → Desligada.

Componente	Papel
App Service (Linux, Python)	Hospeda o portal. O login é feito pelo próprio App Service com o Entra ID (somente contas da organização).
Managed Identity	Identidade do portal para o Microsoft Graph e o Storage. Sem senha, sem certificado, sem segredo a renovar.
Azure Table Storage	Solicitações, perfis, auditoria e estado do agendador. Acesso só pela identidade (chaves de acesso desativadas).
Logic App	Agendador: chama o portal de hora em hora para licenças, ativações, desligamentos e anonimização.
Application Insights / Log Analytics	Monitoramento e logs técnicos, com limite diário de ingestão e sem dados sensíveis.
GitHub Actions	Testa cada mudança e publica no Azure com login federado (OIDC), sem segredo guardado no GitHub.

14 Segurança

O portal tem permissões fortes no Microsoft 365 — ele cria contas e remove acessos. Por isso, a segurança foi desenhada em camadas.

Nada para vaziar

- **Nenhum segredo:** o portal usa Managed Identity para o Microsoft Graph e o Storage; o login dos usuários não usa client secret; a publicação pelo GitHub usa login federado (OIDC). Não há senha, certificado ou chave em arquivos, no GitHub ou nas configurações.
- **Senhas e códigos nunca são guardados:** a senha inicial é aleatória e descartada; o código de acesso é mostrado uma vez, com cache desativado, e nunca vai para banco, log ou e-mail.

Quem pode o quê

- **Login restrito à organização** e revalidado no servidor (organização e aplicativo conferidos em cada requisição).
- **Papéis verificados em cada rota do servidor;** o menu apenas reflete os papéis, não é o controle de acesso.

- **O navegador nunca escolhe grupos:** o RH escolhe um perfil; os grupos vêm do perfil, que foi validado pelo administrador no Microsoft 365.
- **Grupos protegidos:** grupos com funções administrativas, dinâmicos e os grupos de papéis do portal nunca podem ser usados.
- **Sem exclusão:** o portal não tem permissão para excluir usuários nem para alterar administradores.

Proteções da aplicação

Proteção	Como funciona
Modo simulação	Ligado por padrão: nada é alterado no Microsoft 365 até o administrador desligá-lo conscientemente.
Limite diário de contas	Evita criação em massa por erro ou abuso.
Proteção contra CSRF	Formulários com token e verificação de origem.
Cabeçalhos de segurança	CSP restritiva (nenhum script ou estilo externo ou embutido), HSTS, bloqueio de iframe, <code>nosniff</code> , sem cache.
Validação de entrada	Limites de tamanho e caracteres proibidos em todos os campos que chegam ao Microsoft 365.
Idempotência e concorrência	Reenvios não duplicam; gravações com controle de versão; a execução do desligamento é reservada antes de escrever.
Dependências e segredos	A cada mudança, o CI roda lint, 332 testes automatizados, auditoria de dependências e varredura de segredos (gitleaks).

Seja realista sobre o risco

Quem consegue publicar código no portal ganha, na prática, as permissões do portal no Microsoft 365. Proteja a branch principal (pull request e CI obrigatórios), limite quem pode escrever no repositório e exija aprovação para publicar em produção.

15 Permissões no Microsoft 365

As permissões do Microsoft Graph são concedidas à Managed Identity **por nível**, com o script `Set-GraphPermissions.ps1`, que mostra o plano e só aplica após a confirmação `SIM`. Cada nível inclui os anteriores; o script nunca remove permissões.

Nível	Permissões	Para quê
leitura	User.Read.All, Group.Read.All, Organization.Read.All, Domain.Read.All, Policy.Read.AuthenticationMethod	Buscar gestores, verificar logins, listar grupos, licenças e domínios. Não altera nada.

Nível	Permissões	Para quê
criacao	User.ReadWrite.All, User-LifeCycleInfo.ReadWrite.All, GroupMember.ReadWrite.All	Criar a conta desativada, definir gestor e datas, incluir nos grupos.
ciclo-de-vida	User.EnableDisableAccount.All, UserAuthenticationMethod.ReadWrite.All (LicenseAssignment.ReadWrite.All só com licença direta)	Ativar a conta no dia da admissão e gerar o código de acesso inicial.
desligamento	User.RevokeSessions.All	Encerrar as sessões ativas no desligamento.

O login dos usuários usa um App Registration separado, só com `User.Read` (delegada). Revise periodicamente em *Entra* → *Aplicativos empresariais* → *Identities gerenciadas*.

16 Implantação passo a passo

Requisitos

Item	Mínimo
Microsoft Entra ID	Free para o essencial; P1 recomendado (licença por grupo e atribuição de papéis a grupos); Governance opcional.
Microsoft 365	Somente nuvem (sem sincronização com Active Directory local).
Azure	Qualquer assinatura, com permissão de <i>Owner</i> para criar as atribuições da identidade.
Quem implanta	Administrador Global (ou Administrador de Aplicativos + Grupos) para o login e as permissões.
Ferramentas	PowerShell 5.1 ou 7+, Azure CLI com Bicep, Python 3.11+, Git e GitHub CLI.

Todos os scripts são idempotentes (podem rodar de novo), mostram uma pré-visualização e só aplicam após você digitar `SIM`. Nenhum script exclui recursos.

1 Baixar e configurar.

```
git clone https://github.com/<voce>/m365-user-provisioning-portal.git
cd m365-user-provisioning-portal
Copy-Item .env.example .env # preencha tenant, assinatura e domínio
pwsh ./scripts/Test-Prerequisites.ps1 -TenantId <tenant-id> # só leitura
```

2 Criar a infraestrutura no Azure (App Service, identidade, Storage, monitoramento).

```
az login --tenant <tenant-id>
pwsh ./scripts/Deploy-Infrastructure.ps1 -Environment lab -WhatIfOnly
pwsh ./scripts/Deploy-Infrastructure.ps1 -Environment lab
pwsh ./scripts/Deploy-Application.ps1 -Environment lab
```

3 Configurar o login e os papéis (cria o App Registration sem segredo e os três grupos de papéis).

```
pwsh ./scripts/New-EntraApplication.ps1 -Environment lab -AddMeToGroups Administradores
pwsh ./scripts/Deploy-Infrastructure.ps1 -Environment lab
```

4 Conceder a leitura do Microsoft 365 e cadastrar os perfis de onboarding no portal.

```
pwsh ./scripts/Set-GraphPermissions.ps1 -Environment lab
```

5 Testar em modo simulação: faça admissões e desligamentos de teste; nada é alterado no Microsoft 365.

6 Ligar a execução real: conceda os níveis `criacao`, `ciclo-de-vida` e `desligamento`, defina `DRY_RUN=false`, rode `Deploy-Infrastructure.ps1` e reinicie o App Service. Habilite a política de código de acesso temporário no Entra.

- 7 **Opcional:** definir a retenção LGPD e o contato do DPO, e ativar a publicação automática pelo GitHub (capítulo 17).

Custo estimado

Recurso	Laboratório	Produção
App Service	F1 — gratuito (cota diária, sem Always On)	B1 ou superior (sempre disponível)
Storage (Table)	Centavos por mês	Centavos por mês
Logs e monitoramento	Normalmente dentro da franquia gratuita (limite diário de 1 GB)	Conforme volume
Managed Identity, Logic App	Gratuito / centavos	Gratuito / centavos

17 Publicação automática (GitHub Actions)

Com o script `New-GitHubDeployIdentity.ps1`, o repositório passa a publicar sozinho: cada mudança na branch `main` é testada e, se tudo passar, publicada no ambiente de laboratório. Produção só é publicada manualmente, com aprovação.

- **Sem segredo no GitHub:** o login no Azure é federado (OIDC) — o token vale minutos e só é emitido para o ambiente e a branch autorizados.
- **Escopo mínimo:** a identidade de publicação só pode alterar o próprio Web App, nada mais na assinatura.
- **Versão conferida:** a publicação só termina quando o portal responde com a versão nova.

```
gh auth login
pwsh ./scripts/New-GitHubDeployIdentity.ps1 -Environment lab # mostra o plano e pede SIM
```

18 Operação e solução de problemas

Rotina recomendada

- **Diariamente:** abrir o Painel, conferir falhas e aprovações pendentes.
- **Semanalmente:** conferir licenças disponíveis e a última execução do agendador.
- **Mensalmente:** revisar membros dos grupos de papéis e as permissões da identidade; exportar a auditoria, se a política da empresa pedir.

As telas mostram mensagens em linguagem simples. O detalhe técnico de cada falha fica no log do App Service / Application Insights.

Mensagem na tela	O que fazer
"O portal não tem permissão ... (código 403)"	Conceder o nível de permissão necessário com <code>Set-GraphPermissions.ps1</code> e reiniciar o App Service. No desligamento, contas com funções administrativas precisam ser tratadas manualmente.

Mensagem na tela	O que fazer
"Não há licenças disponíveis"	Comprar ou liberar licenças; o agendador tenta de novo sozinho.
"O Microsoft 365 recusou o código de acesso"	Habilitar a política de código de acesso temporário (Temporary Access Pass) no Entra e incluir os colaboradores.
"O Microsoft 365 não respondeu agora"	Nada: instabilidade momentânea; nova tentativa automática.
Agendador parado há mais de 2 horas	Ver o histórico da Logic App no portal do Azure; se houver erro 401/403, rodar <code>New-EntraApplication.ps1</code> novamente.
"Limite diário de contas atingido"	Aguardar o dia seguinte ou aumentar o limite nas configurações.

Guia completo: `docs/SOLUCAO_DE_PROBLEMAS.md` no repositório.

19 Configurações

As configurações ficam no arquivo `.env` (que nunca é versionado) e são levadas ao App Service pelo script de infraestrutura. Nenhuma delas é segredo.

Configuração	Padrão	Descrição
DRY_RUN	true	Modo simulação: nada é alterado no Microsoft 365.
M365_DEFAULT_DOMAIN	—	Domínio verificado usado nos novos logins.
UPN_PATTERN	{nome}. {ultimo_sobrenome}	Padrão do login.
LICENSE_MODE	group	Licença por grupo (recomendado, exige P1) ou direta.
LICENSE_LEAD_DAYS	1	Quantos dias antes da admissão a licença é atribuída.
TAP_LIFETIME_MINUTES	480	Validade do código de acesso inicial (limitada pela política do Entra).
OFFBOARDING_BLOCK_HOUR	18	Hora do bloqueio no último dia de trabalho.
PROVISIONING_DAILY_LIMIT	20	Máximo de contas criadas por dia.
TIMEZONE	America/Sao_Paulo	Fuso usado para "hoje" e para o horário do bloqueio.
LGPD_RETENTION_DAYS	0	Dias após a conclusão para anonimizar (0 = desativado; sugestão 730).
PRIVACY_CONTACT	—	Contato do encarregado de dados (DPO).

Referência

A Glossário

Microsoft Entra ID	Serviço de identidade do Microsoft 365 (antigo Azure AD), onde ficam usuários, grupos e permissões.
Microsoft Graph	Interface oficial da Microsoft usada pelo portal para ler e alterar dados do Microsoft 365.
Tenant	O "espaço" da organização no Microsoft 365.
Login (UPN)	Nome de usuário corporativo, no formato de e-mail (ex.: <code>maria.souza@empresa.com</code>).
Código de acesso inicial (TAP)	Temporary Access Pass: código temporário, de uso único, que substitui a senha no primeiro acesso e permite cadastrar o MFA.
MFA	Autenticação multifator: além da senha, uma confirmação no celular ou biometria.
Managed Identity	Identidade do Azure para aplicações, sem senha ou segredo; o Azure cuida das credenciais.
OIDC (login federado)	Forma de o GitHub provar ao Azure quem ele é sem guardar senha, com tokens de curta duração.
Perfil de onboarding	Conjunto de grupos de acesso e licença de uma função, definido pelo administrador.
Modo simulação (DRY_RUN)	Modo em que o portal mostra o que faria, sem alterar nada no Microsoft 365.
Idempotente	Que pode ser executado várias vezes com o mesmo resultado, sem duplicar nada.
Anonimização	Remoção definitiva dos dados pessoais de uma solicitação, mantendo apenas o necessário para rastreabilidade.

B Estrutura do repositório e licença

Pasta	Conteúdo
app/	Aplicação (FastAPI): rotas, regras de negócio, integração com o Graph, armazenamento, telas.
infra/	Infraestrutura como código (Bicep).
scripts/	PowerShell de implantação, login, permissões e identidade de publicação.

Pasta	Conteúdo
docs/	Documentação em Markdown e este PDF (fonte em docs/pdf/).
tests/	Testes automatizados (unidade, rotas, contrato de armazenamento, segurança, interface).
.github/workflows/	CI (testes, Bicep, varredura de segredos) e publicação.

Documentos detalhados no repositório

docs/IMPLANTACAO.md · docs/CONFIGURACAO_ENTRA.md · docs/PERMISSOES_GRAPH.md · docs/CICLO_DE_VIDA.md · docs/DESLIGAMENTO.md · docs/AUDITORIA_E_LGPD.md · docs/REGRAS_DE_NOME.md · docs/CI_CD.md · docs/ARQUITETURA.md · docs/SOLUCAO_DE_PROBLEMAS.md · SECURITY.md

Licença e contribuição

O projeto é distribuído sob a **licença MIT**: pode ser usado, alterado e redistribuído livremente, inclusive comercialmente, mantendo o aviso de copyright. É fornecido "no estado em que se encontra", sem garantias. Contribuições são bem-vindas (veja CONTRIBUTING.md); vulnerabilidades devem ser relatadas de forma privada, conforme SECURITY.md .

Sobre as imagens

As capturas de tela deste documento foram feitas em ambiente de teste com a organização fictícia "Contoso" e pessoas fictícias. Nenhum dado real aparece.